HASH-MAC-PASSWORD

해시·MAC·솔트·키 스트레칭

연관 기출 · 127-1-5, 138-4-2, 127-1-9

한눈에 이해

해시는 지문, MAC은 비밀키를 가진 이의 지문, 비밀번호 저장은 추측을 느리게 하는 별도의 설계입니다.

정의와 핵심 원리

암호학적해시는임의길이입력을 고정길이값으로 매핑하고 역상·제2역상·충돌저항성을목표로 합니다. MAC은 공유키로 메시지무결성과 키 소유자의 인증을 제공하며 HMAC은 해시를안전한 키드구조로 결합합니다.

• 일반 해시는비밀이없어공격자가본문과해시를함께 바꾸면진위를 입증하지못합니다.HMAC은 K와 ipad/opad를 사용하는 안쪽·바깥쪽해시구조입니다. 공유키를 가진양측모두태그를만들수 있으므로제3자에대한부인 방지는전자서명과다릅니다.

• 비밀번호는 작은 후보공간탓에단방향해시도추측검사가 가능합니다.RainbowTable은 미리계산한연쇄를활용해시간·메모리를 절충합니다. 계정별서로 다른 무작위솔트는동일비밀번호해시일치를숨기고사전계산재사용을어렵게하지만온라인추측이나약한비밀번호자체를제거하지 않습니다.

• 키스트레칭은전용비밀번호해싱/KDF의비용 파라미터로 공격자추측 비용을 높입니다. 솔트·해시·알고리즘·비용 버전을 함께 보관하고 로그인시비용상향을지원합니다. 별도 비밀pepper는 솔트와다르며회전·복구 정책이 필요합니다.

• 변조(Modification)는 기존 자료를 권한 없이 변경하는 것으로 송금액을 10에서 100으로 바꾸는 경우입니다. 위조(Fabrication)는 허위 자료·메시지를 진짜처럼 생성·삽입하는 것으로 존재하지 않는 송금 지시를 만드는 경우입니다. 변경 탐지와 생성 주체의 진위 확인을 구분하며, 키 없는 해시만으로는 공격자가 본문과 해시를 함께 새로 만드는 것을 막지 못합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
일반 해시	비밀없음;지문	원본 진위·기밀성없음
MAC/HMAC	공유 비밀키	무결성·양자간인증
비밀번호KDF	솔트·작업 비용	오프라인추측 비용 증가

적용 예제

같은 비밀번호의 저장 비교

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: A/B가 같은 비밀번호사용;솔트sA≠sB

1. 동일한 단순 해시이면두계정의 결과가 같습니다.
2. KDF(password, sA, cost)와KDF(password, sB, cost)는서로 다르게계산됩니다.
3. 공격자는각솔트의후보계산을 다시해야합니다.
4. 온라인속도제한·피싱 대응·MFA도 함께 적용합니다.

결과·해석: 저장 보호와 온라인인증 보호의 다층관계를 설명합니다.

전제·주의: 빠른SHA함수를 반복횟수 없이비밀번호 저장에 그대로쓰는것은적절하지 않습니다.

답안 골격과 혼동 방지

해시성질 → MAC와 서명비교 → RainbowTable → 솔트·스트레칭 → 운영 정책

- 해시는복호하는암호가 아닙니다.
- 솔트를숨겨야만안전한 비밀키로 설명하지 않습니다.

내용을 가리고 회상

1. 충돌과 역상은어떻게다릅니까?
2. HMAC에 부인 방지가없는 이유는무엇입니까?
3. 솔트가있어도 약한비밀번호가 위험한이유는무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 출처 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- RFC2104: HMAC - H. Krawczyk et al. / IETF; 1997-02; 확인 2026-11-05.
- NIST SP800-63B-4 Authentication - NIST; 2025-07; 확인 2026-11-05.
- Internet Security Glossary, Version 2 - R. Shirey / RFC Editor; 2007-08; 확인 2026-11-05.